

An ECC-Based Three-Factor Authentication and Key Management Protocol for Session Key Leakage Resilience in Internet of Drones

Xueru Zhang[✉], Di Wu[✉], and Rui Zhang[✉]

Abstract—As a network with dynamic network topology and limited onboard resources, the Internet of Drones (IoD) suffers various cyberattacks, such as real-time data tampering, clogging, and jamming. The real-time data tampering, especially the session key leakage, in the IoD can distort time-sensitive information and disrupt system operations. Many existing works based on authentication and key agreement perform low efficient and not secure enough for real-time data transmission in the system. In this article, we proposed a three-factor key Agreement and authentication protocol (HEAT) to solve these issues. The HEAT can solve session key leakage during data transmission by refining the user authentication mechanism and introducing the elliptic curve cryptography (ECC) into communications between drones and users. Compared with existing protocols, the HEAT achieves less authentication delay and higher data efficiency. The HEAT is proven secure with numerous experiments under the extended Canetti–Krawczyk (eCK) model.

Index Terms—Elliptic curve cryptography, Internet of Drones (IoD), key agreement, three-factor authentication.

NOMENCLATURE

U_i	User i .
DR_j	Drone j .
SK	Private key of GSS.
PK	Public key of GSS.
$E_P(\alpha, \beta)$	Elliptic curve with coefficients α and β .
B	Base point on the elliptic curve.
(X_i, Y_i)	Coordinates of one elliptic curve point (user i).
(X_s, Y_s)	Coordinates of another elliptic curve point (server).
ID_i^{ue}	Real identity of user i .
RID_i^{ue}	Pseudonymous identity of user i .
RID_i^{re}	Pseudonymous identity of user i when registering.
ID_j^{dr}	Real identity of drone j .
RID_j^{dr}	Pseudonymous identity of drone j .
R_j^{dr}	Random identifier of drone j .
PID_i^{ue}	Dynamic authentication identity of user i .
PID_j^{dr}	Dynamic authentication identity of drone j .

T^{ue}, T^s, T^{dr}	Timestamps of mobile device, GSS, and drones.
$H(\cdot)$	Hash function.
$\parallel$	Concatenation operation.
E_{Auth}	Adversary successfully forges an authentication message and passes verification.
E_{Hash}	Adversary successfully predicts the output of a hash function.
E_{Forge}	Adversary forges authentication based on solving the ECDLP.
E_{EK}	Adversary successfully obtains the session key.

I. INTRODUCTION

IN RECENT years, the rapid improvement of intelligent systems has significantly accelerated the deployment of drones in various domains, such as agricultural inspection, logistics delivery, and environmental monitoring [1]. Secure and stable user access to specified drones can serve various commercial applications. Drones provide cost-effective and ubiquitous wireless connectivity, enabling rapid and flexible deployment, which makes them particularly suitable for time-sensitive tasks.

In the Internet of Drones (IoD), drones are deployed in a large aerial area. The high mobility of drones makes the network topology change frequently. The less-secured communication channels, poor onboard energy, and limited computing resource in IoD make it highly susceptible to several invasive, noninvasive, and semi-invasive cyberattacks [2].

In the IoD, drones are using wireless communications in an open area, which results in a harder detection of malicious users. Traditional authentication mechanisms, such as symmetric encryption and public-key infrastructure (PKI), secure communications with high computing resource consumption and high complexity key management. Thus, the IoD is in great need of a lightweight and high efficient authentication mechanism.

Elliptic curve cryptography (ECC) stands out among cryptographic approaches as a promising solution due to its short key lengths, high security, and low computational cost [3]. ECC-based authentication mechanisms provide strong security with low system resource consumption and communication cost. These advantages of ECC satisfy the authentication mechanism requirements of the IoD. In dynamic topology networks, such as the IoD, data tampering and session key

Received 27 November 2025; accepted 17 December 2025. Date of publication 23 December 2025; date of current version 9 March 2026. (Corresponding author: Di Wu.)

The authors are with the School of Cyber Science and Engineering, Nanjing University of Science and Technology, Nanjing 210014, China (e-mail: xueru_z0726@163.com; diwu_hrb@njjust.edu.cn; zr_official@njjust.edu.cn).

Digital Object Identifier 10.1109/IJOT.2025.3647437

2327-4662 © 2025 IEEE. All rights reserved, including rights for text and data mining, and training of artificial intelligence and similar technologies. Personal use is permitted, but republication/redistribution requires IEEE permission.

See <https://www.ieee.org/publications/rights/index.html> for more information.

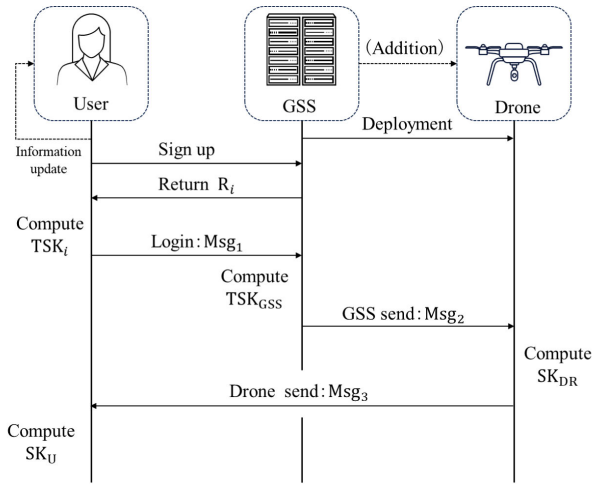


Fig. 1. The architecture of the HEAT protocol.

leakage during mission execution pose serious security threats, necessitating highly efficient authentication protocols to mitigate these vulnerabilities.

In this article, we propose an ECC-based three-factor key Agreement and authentication protocol (HEAT) to enhance the authentication mechanisms used in the IoD. HEAT generates a session key to enable mutual authentication, which secures subsequent data communication between drones and users.

HEAT protocol optimizes the user authentication mechanism and redesigns the pseudonym deployment strategy, which fundamentally addresses session key leakage during data transmission. HEAT reduces authentication delay and improves data efficiency through ECC-based key agreement and carefully designed authentication procedures. These improvements make HEAT both more secure and more efficient than other schemes.

The architecture of HEAT is illustrated in Fig. 1, which consists of three main entities: users, the trusted ground server, and drones. Once authenticated, the drone can establish a secure session with the user. The main contributions of this article are summarized as follows.

- 1) We improve the three-factor authentication protocol by optimizing the exchange of ephemeral session keys between user and GSS.
- 2) In cases where all communication data are fully intercepted and fragmented, HEAT still can prevent session key derivation with redesigned sudo-name deployment.
- 3) The protocol is formally analyzed under the random oracle model (RoM) and extended Canetti–Krawczyk (eCK) model. It is demonstrated that the HEAT can offer a tradeoff between security and efficiency.

The rest of this article is organized as follows. The related works are reviewed in Section II. The preliminaries are presented in Section III. The system model and attack model are briefly explained in Section IV. The proposed protocol is described in Section V. The security analysis of our protocol, the communication cost and the computation cost comparative analysis are performed in Section VI. Finally, Section VII concludes this article.

II. RELATED WORK

In recent years, authentication and key agreement protocols have played a pivotal role in ensuring secure communication within the IoD. Various protocols have been conducted on authentication mechanisms suitable for limited energy, computational, and memory resources. However, most existing schemes still struggle to achieve an optimal balance between security and efficiency.

Yeh et al. [4] proposed an authentication protocol based on ECC for wireless sensor networks, which demonstrated certain effectiveness in securing node authorization and data transmission. Nevertheless, Shi and Gong [5] revealed that this protocol lacks the capability to establish a session key between communicating parties. To address this limitation, Challa et al. [6] introduced a novel ECC-based authentication scheme incorporating digital signatures. Although this scheme enhanced the overall security, it incurred higher computational and communication costs and still exhibited deficiencies in correctness. Subsequently, Nikooghadam et al. [7] designed a lightweight ECC-based authentication protocol tailored for smart city applications. Ali et al. [8] identified several vulnerabilities in the scheme, including susceptibility to replay attacks, internal privilege misuse and impersonation threats, as well as the absence of effective mutual authentication.

Das et al. [9] proposed a three-party authentication framework targeting industrial IoT environments, which was later shown to suffer from critical security flaws by Hussain et al. [10] and Chaudhry et al. [11]. In 2019, Wazid et al. [12] designed an authentication protocol aimed at securing IoT communications, which was capable of defending against various known attacks but failed to adequately preserve user anonymity. Hussain et al. [10] proposed an ECC and biometric-based authentication and key agreement protocol, called NAKAS, specifically for the IoD, claiming resistance to a wide range of known attacks. However, Zhang et al. [13] pointed out significant security weaknesses in their scheme. In the same year, Zhang et al. [14] introduced a multifactor authentication and key agreement protocol that effectively addressed the security issues identified in NAKAS, though it still exhibited correctness flaws.

Mahmood et al. [15] proposed a security-enhanced chaotic-map-based authentication protocol that combines chaotic maps, hash functions, and physically unclonable functions to strengthen resistance against masquerading, anonymity violations, and physical cloning attacks. Saleem et al. [16] proposed a provably secure authentication protocol for mobile clients (PSK-MC) based on puncturable pseudorandom functions. Although these works were developed in different contexts, their techniques and design insights can be cross-applied to IoD networks.

While notable progress has been made in the design of authentication protocols, achieving a secure and privacy-preserving scheme with minimal computational and communication cost remains a critical challenge. Compared with previous studies, the advantage of our protocol lies in optimizing the user authentication mechanism and redesigning pseudonym deployment.

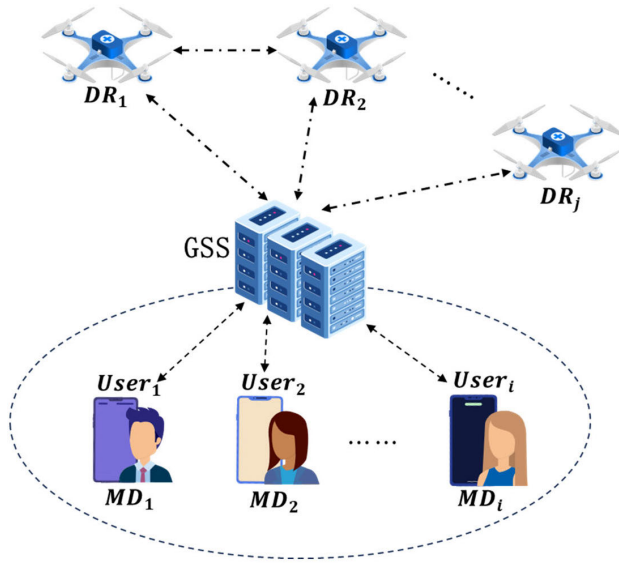


Fig. 2. IoD communication model.

III. PRELIMINARIES

A. Elliptic Curve Cryptography

ECC, first introduced by Miller [3], is a public-key cryptographic scheme based on the algebraic structure of elliptic curves over finite fields.

An elliptic curve over a prime finite field $\mathbb{F}_p$ is typically defined by the Weierstrass equation

$$y^2 \equiv x^3 + ax + b \pmod{p} \quad (1)$$

where $a, b \in \mathbb{F}_p$ and the curve satisfies the nonsingularity condition: $4a^3 + 27b^2 \not\equiv 0 \pmod{p}$ to ensure the absence of singular points. The set of all solutions (x, y) to this equation, together with a special point at infinity $\mathcal{O}$, forms an Abelian group under a well-defined point addition operation. This group adheres to the fundamental properties of closure, associativity, identity, inverses, and commutativity.

The two basic operations in ECC are as follows.

- 1) *Point Addition* $Q + V$: Given two points Q and V on the curve, the sum of two points is geometrically defined as another point R also on the curve.
- 2) *Scalar Multiplication* nQ : This represents the repeated addition of point Q with itself n times, i.e.,

$$nQ = \underbrace{Q + Q + \dots + Q}_{n \text{ times}}.$$

Since the set of points constitutes an Abelian group, the point addition operation is commutative, that is, $Q + V = V + Q$. Although scalar multiplication involves a scalar and a point, and not a true multiplication between two points, it satisfies a similar property

$$nQ = Qn.$$

However, it is important to note that the product of two points (e.g., $Q \cdot V$) is not defined in ECC.

The security of ECC relies on the hardness of the elliptic curve discrete logarithm problem (ECDLP). Given a point

Q and another point $R = nQ$, it is computationally infeasible to determine the scalar n within polynomial time. This intractability serves as the foundation for constructing secure cryptographic primitives such as key generation, encryption, and digital signatures.

For practical ECC deployment, careful selection of curves and security parameters is essential. Using well-established and secure curves will offer high performance and strong security for modern applications, such as NIST curves and Curve25519/Ed25519. Avoid using deprecated or weak curves such as P-192 or P-224. ECC key lengths should be based on the desired level of symmetric security. The following table provides key sizes:

Symmetric Security	Recommended ECC Key Size
128-bit	256-bit
192-bit	384-bit
256-bit	512-bit

B. Random Oracle Model

The RoM [17] is a theoretical framework used for the formal security analysis of cryptographic algorithms and protocols that rely on hash functions. The main advantage of RoM is that it abstracts away the concrete implementation details of hash functions, thus significantly simplifying the security proofs of cryptographic protocols [18].

In RoM, hash functions are treated as random oracles $H: \{0, 1\}^* \rightarrow \{0, 1\}^l$, which means that for each unique query x , $H(x)$ outputs a uniform random string of length l , and for repeated queries, $H(x)$ returns the same result as before.

C. System Model

1) *Network Model*: The system network model of the IoD is shown in Fig. 2, which primarily consists of three types of entities: drones, ground server stations (GSS), and legitimate users.

- 1) *Internet of Drones*: The IoD is a self-organizing and dynamic network structure formed by multiple drones. Each drone is capable not only of independently executing tasks and collecting environmental data but also of communicating and cooperating with other nodes [19]. Depending on the network topology, communication between drones can occur through direct point-to-point connections or via multihop relay strategies to reliably deliver task data to target drones or the GSS [20].
- 2) *Ground Server Station*: The GSS serves as the trusted management center within the IoD system. GSS is responsible for receiving and storing data transmitted from the IoD and acts as an authentication service provider, offering data access services to authenticated users. During communication, the GSS functions as a trusted third party, assisting in session key agreement between drones and users to ensure communication security [21].
- 3) *Users*: They refer to external entities possessing legitimate identities and access privileges. Legitimate users

must first authenticate their identities to the GSS via the authentication mechanism. Upon successful authentication, users can access the GSS through a public channel to obtain the required data resources or directly communicate with specific drones to retrieve the data collected by the drones.

2) *Adversarial Model*: This article ensures the security of HEAT in real-world communication environments by adopting the eCK model as the theoretical foundation for formal security analysis. The eCK model, proposed by LaMacchia et al. [22], is currently regarded as one of the mainstream standards for evaluating the security of key agreement protocols.

Based on the adversarial capabilities defined in the eCK model, we assume that the adversary possesses the following powers.

- 1) The adversary can obtain long-term partial secret keys of the user or drone.
- 2) The adversary can compromise ephemeral private keys temporarily stored in the memory of user or drone at some stages.
- 3) The adversary is capable of eavesdropping, modifying, replaying, delaying, or even forging protocol messages in an attempt to deceive the communicating parties.
- 4) The adversary has a fundamental limitation. They cannot simultaneously obtain both the long-term and ephemeral secret keys of both parties involved in a given session.

IV. PROPOSED PROTOCOL

In this section, the details of HEAT protocol are designed for providing access to the drones.

A. Setup

GSS selects an elliptic curve $E_p(\alpha, \beta)$ defined over the finite field $\mathbb{Z}_p^*$ and a base point B over $E_p(\alpha, \beta)$, where $n = \infty$. The GSS chooses a private key SK , computes the corresponding public key $PK = SK \cdot B$, and defines a one-way hash function $h(\cdot)$. Additionally, GSS selects a probabilistic generation function $Gen(\cdot)$ and an error recovery function $Rep(\cdot)$, where $Gen(BIO_i) = (\sigma_i, \tau_i)$, and if $d(BIO_i, BIO'_i) \leq t$, then $Rep(BIO'_i, \tau_i) = \sigma_i$. Here, $\sigma_i \in \{0, 1\}^l$ denotes a biometric key of length l , τ_i is a public parameter, and t represents the allowed error threshold. The parameters $\{E_p(\alpha, \beta), B, h(\cdot), PK, Gen(\cdot), \text{ and } Rep(\cdot), t\}$ are publicly announced by the GSS, while the private key SK is securely kept confidential.

B. Drone Pre-Deployment

Before network deployment, the GSS conducts offline registration for all drones. For each drone, the GSS selects an identity $ID_j^{dr} : \{j = 1, 2, \dots, n\}$ and a unique random number R_j^{dr} . It then computes the corresponding pseudoidentity as $RID_j^{dr} = h(ID_j^{dr} || SK || R_j^{dr})$. Finally, the GSS stores $\{ID_j^{dr} \text{ and } R_j^{dr}\}$ in the memory of each drone and $\{ID_j^{dr}, RID_j^{dr}, \text{ and } R_j^{dr}\}$ in its own database.

C. User Registration

The user U_i selects an identity ID_i^{ue} , randomly generates a value r_0 , and computes the pseudoidentity as $RID_i^{ue} = h(ID_i^{ue} || r_0)$. The value RID_i^{ue} is then transmitted to the GSS through a secure channel. Upon receiving this information, the GSS computes $R_i = h(RID_i^{ue} || SK)$ and sends a reply containing R_i back to U_i through secure channel. After receiving the GSS registration response, the user U_i selects a password PWD_i and inputs their biometric data BIO_i into the mobile device MD_i . MD_i computes $Gen(BIO_i) = (\sigma_i, \tau_i)$, $A_i = h(ID_i^{ue} || PWD_i || \sigma_i)$, $R'_i = R_i \oplus h(PWD_i || \sigma_i)$, and $RID_i^{re} = RID_i^{ue} \oplus h(ID_i^{ue} || \sigma_i)$. The user U_i stores $\{A_i, R'_i, \tau_i, Gen(\cdot), Rep(\cdot), h(\cdot)\}$ in the memory of the mobile device MD_i .

D. Authentication

A registered user U_i , when needing to obtain real-time data or perform other operations from the corresponding deployed drone DR_j , initiates the authentication process and shares a secret key with the drone via the GSS. Using the principles of elliptic curves, the user and the GSS can compute the same TSK_i and TSK_{GSS} from different information without transmitting it. To successfully complete this phase, the following steps are executed among U_i , GSS, and DR_j . The following steps are illustrated in Fig. 3.

- 1) *Step 1*: The user U_i inputs ID_i , PWD'_i , and BIO'_i again on the mobile device and computes $\sigma_i = Rep(BIO'_i, \tau_i)$, $A'_i = h(ID_i^{ue} || PWD'_i || \sigma_i)$, and checks $A_i \stackrel{?}{=} A'_i$. If the check succeeds, U_i selects random numbers $r_1, r_2 \in \mathbb{Z}_p^*$, and continue calculating $TSK_i = M_i = r_1 \cdot P$, $N_i = r_1 \cdot PK = (X_i, Y_i)$, $R_i = R'_i \oplus h(PWD_i || \sigma_i)$, $RID_i^{re} = RID_i^{re} \oplus h(ID_i^{ue} || \sigma_i)$, $G = h(R_i || T^{ue})$, $E_i = G \oplus X_i$, $r'_2 = r_2 \oplus X_i$, $RID_i^{ue'} = RID_i^{ue} \oplus X_i$, and $ID_j^{dr'} = ID_j^{dr} \oplus X_i$. Finally, U_i sends the login request message $Msg_1 = \{E_i, RID_i^{ue'}, ID_j^{dr'}, r'_2, M_i, T^{ue}\}$ to the GSS through an open channel.
- 2) *Step 2*: Upon receiving the message, the GSS verifies the time freshness $|T^{ue} - T^c| < \Delta T$. If the verification succeeds, GSS computes $TSK_{GSS} = N_S = M_i \cdot SK = (X_s, Y_s)$, $G = E_i \oplus X_s$, $r_2 = r'_2 \oplus X_s$, $ID_j^{dr} = ID_j^{dr'} \oplus X_s$, and $RID_i^{ue} = RID_i^{ue'} \oplus X_s$. The GSS checks $G \stackrel{?}{=} h(h(RID_i^{ue} || SK) || T^{ue})$. If the check passes, the user is considered authenticated; otherwise, the session is terminated immediately. Then, the GSS selects a timestamp T^s and checks if ID_j^{dr} exists in its database. On the existence, the GSS calculates $RID_j^{dr} = h(ID_j^{dr} || SK || R_j^{dr})$, $V = h(RID_i^{ue} || r_2 || ID_j^{dr} || T^s || R_j^{dr} || RID_j^{dr})$, $V' = (RID_j^{dr} || R_j^{dr}) \oplus V$, $W = h(RID_j^{dr} || V || T^s)$, $W' = RID_j^{dr} \oplus W$, $PID_i^{ue} = h(N_S || RID_i^{ue})$, $PID_i^{dr} = h(RID_i^{dr} || T^s || ID_j^{dr})$, $M_1 = h(R_j^{dr} || T^s) \oplus h(X_s || Y_s)$, and $M_2 = RID_j^{dr} \oplus h(R_j^{dr} || T^s || ID_j^{dr})$. The GSS sends the message $Msg_2 = \{PID_i^{ue}, PID_i^{dr}, V', W', T^s, M_1, M_2\}$ to the drone DR_j through an open channel.
- 3) *Step 3*: Upon receiving Msg_2 , DR_j first checks the time freshness $|T^s - T^c| < \Delta T$. If the verification succeeds, DR_j continues to compute $RID_j^{dr} = M_2 \oplus h(R_j^{dr} || T^s || ID_j^{dr})$ and check $PID_i^{dr} \stackrel{?}{=} h(RID_j^{dr} || T^s || ID_j^{dr})$.

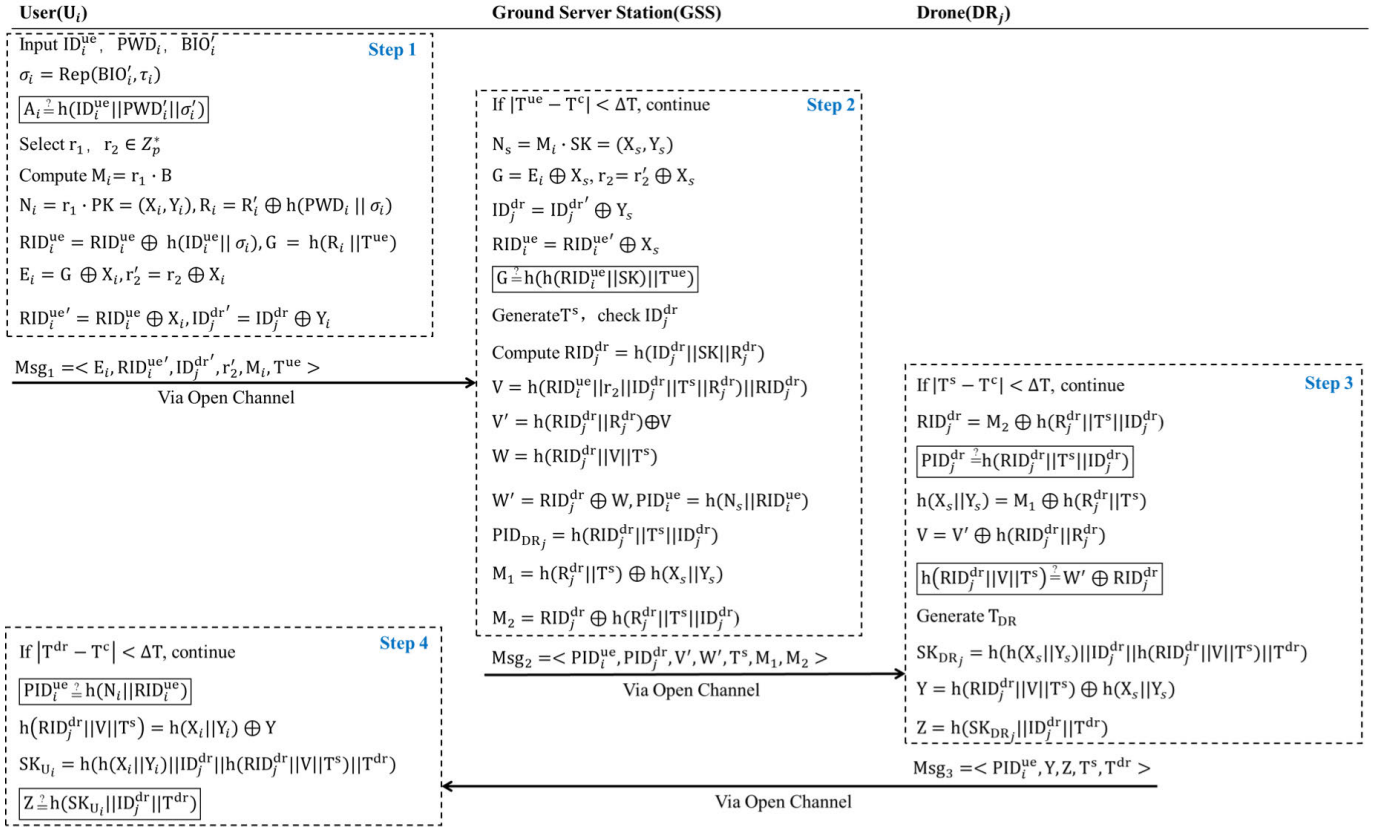


Fig. 3. Proposed login and authentication phase.

If the check succeeds, it computes $h(X_s || Y_s) = M_1 \oplus h(R_j^{dr} || T^s)$ and $V = V' \oplus h(RID_j^{dr} || R_j^{dr})$ and verifies $h(RID_j^{dr} || V || T^s) \stackrel{?}{=} W' \oplus RID_j^{dr}$. If successful, DR_j selects a timestamp T^{dr} and computes the session key $EK_{DR_j} = h(h(X_s || Y_s) || ID_j^{dr} || h(RID_j^{dr} || V || T^s) || T^{dr})$. Then, it calculates $Y = h(RID_j^{dr} || V || T^s) \oplus h(X_s || Y_s)$ and $Z = h(EK_{DR_j} || ID_j^{dr} || T^{dr})$. Finally, DR_j sends $Msg_3 = \{PID_i^{ue}, Y, Z, T^s, T^{dr}\}$ to U_i .

- 4) *Step 4:* Upon receiving Msg_3 from the corresponding drone, U_i first checks time freshness $|T^{dr} - T^c| < \Delta T$. If the verification succeeds, it verifies $PID_i^{ue} \stackrel{?}{=} h(N_i || RID_i^{ue})$. If this holds, U_i computes $h(RID_j^{dr} || V || T^s) = h(X_i || Y_i) \oplus Y$ and $EK_{U_i} = h(h(X_i || Y_i) || ID_j^{dr} || h(RID_j^{dr} || V || T^s) || T^{dr})$ and finally checks $Z \stackrel{?}{=} h(EK_{U_i} || ID_j^{dr} || T^{dr})$. If verified, U_i and DR_j save the session key $EK_{U_i} = EK_{DR_j}$ to ensure the security of future communications.

E. User Information Update

The user U_i can update their credentials in this phase.

1) *User Authentication:* The user U_i inputs their current identity ID_i^{ue} , old password PWD_{old_i} , and old biometric data BIO_{old_i} . The mobile device MD_i computes $\sigma_{old_i} = \text{Rep}(BIO_{old_i}, \tau_{old_i})$ and verifies whether $A_{old_i} = h(ID_i^{ue} || PWD_{old_i} || \sigma_{old_i})$.

2) *Information Update:* If the verification is successful, MD_i prompts the user to input new biometric data BIO_{new_i}

and a new password PWD_{new_i} . After receiving the input, the device computes $\text{Gen}(BIO_{new_i}) = (\sigma_{new_i}, \tau_{new_i})$, $A_{new_i} = h(ID_i^{ue} || PWD_{new_i} || \sigma_{new_i})$, and $R_{new_i} = R_{old_i} \oplus h(PWD_{old_i} || \sigma_{old_i}) \oplus h(PWD_{new_i} || \sigma_{new_i})$.

Finally, the mobile device MD_i replaces the stored data $\{A_{old_i}, R_{old_i}, \tau_{old_i}\}$ with $\{A_{new_i}, R_{new_i}, \tau_{new_i}\}$.

F. Drone Addition

The process of dynamically adding a drone to the existing network is similar to the drone deployment phase. The GSS selects an identity $ID_{new_j}^{dr}$ and a unique random number R_j^{dr} for the new drone. It then computes the corresponding pseudo-identity as $RID_{new_j}^{dr} = h(ID_{new_j}^{dr} || SK || R_j^{dr})$, where SK is the private key of the GSS. The GSS stores $\{ID_{new_j}^{dr}, RID_{new_j}^{dr}, R_j^{dr}\}$ in the memory of the drone and saves $\{ID_{new_j}^{dr}, R_j^{dr}\}$ in its own database.

V. SECURITY ANALYSIS

A. Provable Security

This section demonstrates the provable security of HEAT under the eCK model. The Host is an idealized entity that emulates the correct implementation of the protocol and is used to facilitate the analysis of the security of protocol against adversarial behavior. The adversary A is modeled as a powerful entity capable of fully controlling the communication channel. Specifically, A can perform various operations such as eavesdropping, tampering, replaying, deleting, and forging

messages. A is allowed to issue session ephemeral key reveal queries, static private key reveal queries. The adversary A can also issue queries, in which Host returns either the real session key or a random value.

The protocol security requirement is that the adversary A should not be able to distinguish between a real session key and a random value, i.e., the indistinguishability of the key is preserved. To ensure the hash function behaves randomly and consistently under the RoM, the Host simulates all hash function behaviors. Specifically, for the hash function H , the challenger maintains a hash query list L_h to store all input-output pairs queried by the adversary. For each query to hash function H , the Host performs the following steps.

- 1) Check whether the same input exists in the record table L_h .
- 2) If it exists, return the previously recorded output value.
- 3) If it does not exist, uniformly select an output value from the output space at random, store the new (input, output) pair in L_h , and return the output to the adversary.

Nomenclature summarizes the definitions of critical security events used in the security analysis of HEAT.

Theorem 1: Under the RoM and the hardness assumption of the ECDLP, the probability that adversary A successfully forges a valid authentication message and breaks mutual authentication is negligible.

Proof: To break mutual authentication, the adversary must accomplish one of the following.

- 1) Successfully guess the hash output $h(\cdot)$.
- 2) Successfully forge authentication messages related to random values (e.g., N_i , N_s , or R_j^{dr}).

The success probability of the adversary can be bounded as follows:

$$\Pr(E_{\text{Auth}}) \leq \Pr(E_{\text{Hash}}) + \Pr(E_{\text{Forge}})$$

where $\Pr(E_{\text{Hash}}) \approx (q_h/2^l)$, q_h is the number of hash queries, and l is the output length of the hash function. $\Pr(E_{\text{Forge}}) \leq \text{Adv}_{\text{ECDLP}}(A)$, which is the probability that the adversary solves the ECDLP within polynomial time.

To successfully forge the first message Msg_1 , the adversary would need to break $G = h(R_i \| T^{\text{ue}})$ or forge X_i . Since r_1 is randomly chosen and $M_i = r_1 \cdot B$, solving for r_1 is equivalent to computing $r_1 = \log_B M_i$, which is an instance of ECDLP and is computationally infeasible. Assuming that the adversary can forge Msg_1 , the success probability is $\Pr(E_{M_1}) \leq (1/p)$, where p is the order of the elliptic curve group, typically on the order of 2^{256} .

Similarly, the success probabilities for forging Msg_2 and Msg_3 are, respectively, $\Pr(E_{M_2}) \leq (1/(p \cdot q_h^2))$ and $\Pr(E_{M_3}) \leq (1/(p \cdot q_h))$. Therefore, the total probability that the adversary successfully forges any authentication message is

$$\Pr(E_{\text{Auth}}) \leq \frac{1}{p} + \frac{1}{p \cdot q_h^2} + \frac{1}{p \cdot q_h}.$$

Since p is large and q_h is polynomially bounded, the overall success probability is negligible. Hence, under the ECDLP hardness assumption and the RoM, $\Pr(E_{\text{Auth}})$ is negligible, and Theorem 1 is proved.

Theorem 2: Under the RoM and the ECDLP hardness assumption, the advantage of adversary A in distinguishing the session key from a random string in the eCK model is negligible.

Proof: The adversary's success probability is

$$\Pr(E_{\text{EK}}) \leq \Pr(E_{\text{Hash}}) + \Pr(E_{\text{Forge}}).$$

In the eCK model, adversary A may know the session key or random value of one party (e.g., r_1 and r_2), but not all secret values of both parties. Therefore, to infer the session key successfully, A must either guess the output of $\text{EK}_{\text{DR}_j} = h(h(X_s \| Y_s) \| \text{ID}_j^{\text{dr}} \| h(\text{RID}_j^{\text{dr}} \| V \| T^s) \| T^{\text{dr}})$ or recover the random values r_1 and r_2 .

If A attempts to directly guess the hash output, the probability is $\Pr(E_{\text{Hash}}) \approx (q_h/2^l)$. If A is able to solve the ECDLP, then

$$\Pr(E_{\text{EK}}) \leq \frac{q_h}{2^l} + \text{Adv}_{\text{ECDLP}}(A).$$

Since q_h is polynomial and 2^l is typically very large, the success probability of A is negligible. Thus, under the RoM and the ECDLP assumption, $\Pr(E_{\text{EK}})$ is negligible, which completes the proof of Theorem 2.

B. Security Assurance

HEAT provides protection against various attacks. Tampering attempts are prevented through cryptographic integrity checks and authentication, which detect and reject unauthorized modifications. Clogging attacks are mitigated by lightweight rate limiting and verification that filters out illegitimate traffic. Jamming attacks are addressed using adaptive frequency hopping and redundant paths, ensuring reliable message delivery even under interference. Together, these measures help HEAT maintain strong performance and security in diverse attack scenarios.

1) *Private Key Leakage Attack:* The private key of drones is used for communication between the drone, the GSS, and the user. As shown in Fig. 4, in the HEAT, although adversary A can obtain $h(\text{RID}_j^{\text{dr}} \| V \| T^s)$, A cannot obtain the private random identifier R_i of users or the private key SK of GSS and thus cannot compute the shared point (X_i, Y_i) . Additionally, A must acquire the deployment-specific random identifier of the drone R_j^{dr} to derive the private key of drones. According to the IoD threat model assumptions, A cannot access drone deployment information while offline, and therefore cannot compute the private key of drones.

2) *Session Key Leakage Attack:* In the proposed authentication and key agreement protocol, the session key generation mechanism is designed to ensure strong security and robustness against attacks. The session key is computed as $\text{EK}_{\text{DR}_j} = h(h(X_s \| Y_s) \| \text{ID}_j^{\text{dr}} \| h(\text{RID}_j^{\text{dr}} \| V \| T^s) \| T_{\text{DR}})$ or $\text{EK}_{U_i} = h(h(X_i \| Y_i) \| \text{ID}_j^{\text{dr}} \| h(\text{RID}_j^{\text{dr}} \| V \| T^s) \| T_{\text{DR}})$, where $h(\cdot)$ is a secure cryptographic hash function with strong collision resistance and one-way properties. The terms $h(X_i \| Y_i)$ and $h(X_s \| Y_s)$ are computed using the private randomness of users r_1 and r_2 and the private key of GSS SK.

According to the assumed security model in this work, the adversary A is considered a powerful entity capable of

User

Input ID_i^{ue} , PWD_i , BIO_i'

.....

$$A_i = h(ID_i^{ue} || PWD_i' || \sigma_i')$$

Select $r_1, r_2 \in Z_p^*$ Compute $M_i = r_1 \cdot B$

$$N_i = r_1 \cdot PK = (X_i, Y_i)$$

.....

Not accessible
Not accessible
A intervenes and begins forging information

$$Msg_A = \langle E_i, RID_i^{ue'}, ID_j^{dr'}, r_2', M_i, T^{ue} \rangle$$

Via Open Channel

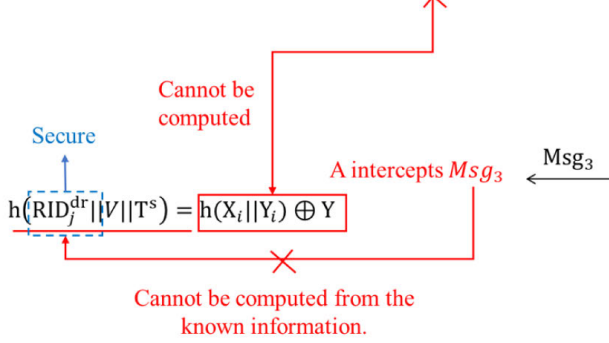


Fig. 4. Resisting private key leakage attacks.

both passive and active attacks. Specifically, the adversary can fully control the public communication channel and perform eavesdropping, replaying, message injection, and modification. However, A is assumed to have no access to the internal storage of the mobile device or the ground server and thus cannot retrieve the secret random values or the private key SK.

Under this model, since the session key computation critically depends on these confidential parameters, even with complete access to the exchanged messages, the adversary is unable to perform a successful session key disclosure attack.

3) *Drone Impersonation Attack*: In the IoD environments, drone masquerade attacks represent a highly threatening form of active attack. Adversaries attempt to deceive the GSS or legitimate users by masquerading as a legitimate drone in the system, causing them to mistakenly trust the adversary A or the masquerading puppet drone as a legitimate drone node. Through this approach, adversaries can illegally access the system, perform unauthorized data access, and steal critical data, thereby seriously threatening the confidentiality, integrity, and availability of the system. As shown in Fig. 5, in the HEAT, if the adversary A cannot derive the private key of each drone through computation, they must directly obtain or manipulate the random identifier of drones R_{DR_j} . The drone random identifier R_{DR_j} is stored offline in both the GSS and drone during the deployment phase, and any modification by the adversary will cause the masquerading drone to fail

TABLE I

SECURITY ATTRIBUTE COMPARISON AMONG PROTOCOLS

Attribute	[6]	[10]	[12]	[14]	[23]	[24]	[25]	Prop.
Correctness Verification	✓	✓	✓	×	✓	✓	✓	✓
User Anonymity	✓	✓	✓	✓	×	×	×	✓
Insider Attack	✓	✓	×	✓	✓	✓	×	✓
Password Guessing	✓	✓	✓	✓	✓	✓	×	✓
DoS Attack	✓	✓	×	✓	✓	✓	✓	✓
MITM Attack	✓	✓	✓	✓	✓	✓	✓	✓
Password Update	✓	✓	✓	✓	—	✓	✓	✓
Biometric Update	✓	✓	✓	✓	—	✓	×	✓
Session Key Agreement	✓	✓	×	✓	✓	✓	✓	✓
Drone Impersonation	✓	×	✓	✓	✓	✓	✓	✓
User Impersonation	✓	×	×	✓	✓	✓	×	✓
Session Key Security	✓	×	×	✓	✓	×	✓	✓

Note: ✓: Security feature Provisioning; ×: Nonprovision of security feature; —: N/A.

communication. Therefore, HEAT can effectively resist drone masquerade attacks.

4) *User Impersonation Attack*: In modern IoD and IoT systems, the real identities of communication entities are closely linked to highly sensitive information such as their affiliated organizations, geographic locations, and behavioral patterns. Identity information leaking during transmission can lead to user behavior tracking, precise device location, and consequently to serious privacy breaches, malicious interference, or even physical attacks. As shown in Fig. 6, an adversary A attempting to steal the identity of a legitimate user could intercept communications between drones and users if the impersonation succeeds, resulting in significant data leakage and security risks. Therefore, protecting user identity anonymity is crucial for privacy preservation. In the HEAT, the drone and the user identity identifiers transmitted over the public network are computed as $RID_j^{dr} = h(ID_j^{dr} || SK || R_j^{dr})$ and $RID_i^{ue} = h(ID_i^{ue} || r_0)$, respectively. By introducing random factors, the pseudonymous identities generated in each communication session are unique and unpredictable, thus achieving user identity anonymity protection.

5) *Insider Attack*: In the NAKAS, once a user successfully registers, they can access data in the IoD network without any control. However, successfully registered users are not necessarily trustworthy; they may be spies or former employees. Therefore, effective management of these users is crucial for the security of the drone network. In this article, we introduce a new TSK in the GSS to implement effective access control for registered users, thereby defending against insider attacks.

VI. SECURITY AND PERFORMANCE ANALYSIS

A. Security Analysis

The comparison results between our proposed protocol and six representative schemes [6], [10], [12], [23], [24], [25] with respect to the security attributes defined in the security standards of [26] are shown in Table I. In the table, “✓” indicates that the protocol possesses the corresponding security attribute or can resist the corresponding attack, while “×” indicates the lack of such an attribute or vulnerability to the corresponding attack.

As shown in Table I, although protocols proposed in [6], [10], [12], [23], [24], and [25] provide fundamental security mechanisms, such as identity authentication and session key

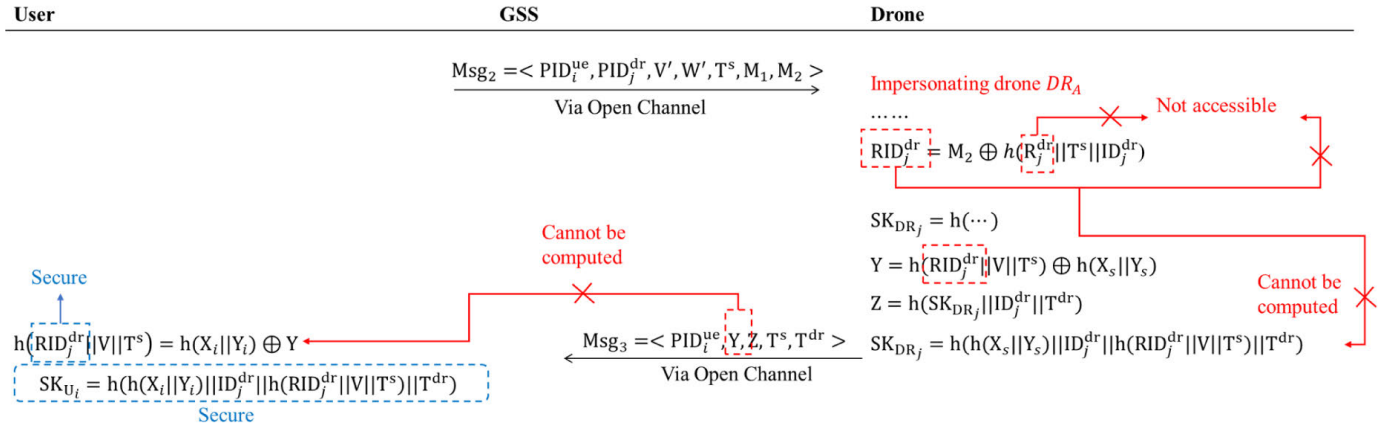


Fig. 5. Resisting impersonation attacks.

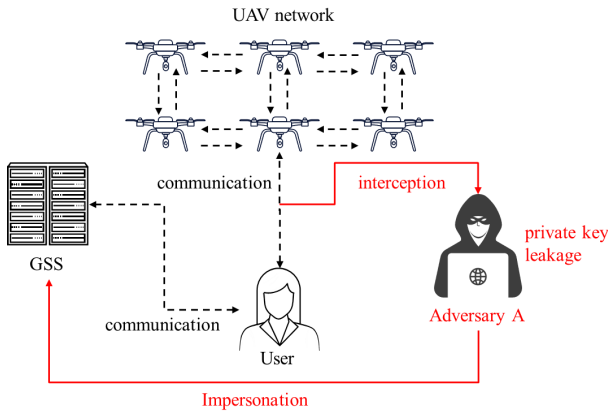


Fig. 6. Identity anonymity protection against threats.

agreement, they still suffer from significant shortcomings in several critical security issues. Some even pose systemic security risks. In contrast, HEAT demonstrates superior performance in terms of comprehensive security features and attack resistance.

Specifically, schemes in [12] and [24] fail to ensure user anonymity, exposing user identity during communication and posing serious privacy risks, especially in privacy-sensitive IoT scenarios. By integrating a pseudonym mechanism, our protocol conceals user and device identities effectively, enhancing privacy protection throughout the communication process.

Regarding insider attack resistance, the schemes in [23] and [25] lack sufficient isolation and key protection, making them vulnerable to privilege abuse. HEAT incorporates key-binding and logical authentication designs, significantly improving its resilience against insider threats.

In [10], drone impersonation attacks are insufficiently addressed due to the lack of identity binding in the protocol. This allows adversaries to impersonate legitimate drones by acquiring partial identity information. In our protocol, device identifiers are bound to random private keys during deployment and authenticated using hash functions and timestamps, effectively preventing such impersonation.

In particular, the protocols in [10], [23], and [25] also exhibit weaknesses in resisting user impersonation attacks and

TABLE II
COMMUNICATION COST COMPARISON

Protocol	Total Transmission (bits)	Rounds
[6]	2528	3
[10]	2208	3
[14]	2374	3
[25]	2720	4
Proposed	2336	3

All protocols perform three rounds of communication.

ensuring session key security. In particular, their session key derivation mechanisms lack forward secrecy, rendering them susceptible to key recovery if prior information is compromised. In contrast, the session key in our scheme is derived from multiple dynamic factors and is used only once per session, ensuring secrecy even in the event of historical data leakage.

As identified in [14], the protocol suffers from incorrect verification from drone to mobile device, which undermines the mutual authentication process. In particular, there is a clear computational error in the authentication formula used for verifying the identity of drones on the mobile side, which can lead to authentication failure or allow an attacker to bypass identity verification. To address this issue, our proposed protocol modifies the mutual authentication phase by updating the computation method used for drone-to-user identity verification.

B. Communication Performance Comparison

HEAT introduces additional fields, including a 128-bit random identifier, a 32-bit timestamp, a 160-bit hash output, and a 320-bit ECC parameter. A communication cost comparison with other schemes is presented in Table II.

As shown in Table II, these protocols require at least three communication rounds. While HEAT demonstrates a lower computational cost than the schemes of Challa et al. [25], its most notable improvement lies in data efficiency compared with Zhang et al. [14]. By optimizing the user authentication mechanism and redesigning the pseudonym of drones, HEAT achieves a more practical balance between performance and resistance to more attacks.

TABLE III
EXECUTION TIME OF BASIC OPERATIONS

Operation	Mobile Device (ms)	GSS (ms)	Drone (ms)
T_e	5.116	0.926	4.107
T_a	0.013	0.006	0.018
T_h	0.009	0.004	0.006
T_r	2.011	0.118	1.185
T_f	5.116	-	-

TABLE IV
COMPUTATION TIME COST COMPARISON

	Mobile Device	GSS	Drone	Total (ms)
[6]	$5T_e + 5T_h + T_f + T_r$	$5T_e + 4T_h + T_r$	$3T_h + 4T_e + T_r$	55.147
[10]	$2T_e + 8T_h + T_f + 2T_r$	$T_e + 7T_h$	$6T_h$	20.432
[14]	$2T_e + 8T_h + T_f + 2T_r$	$T_e + 10T_h$	$7T_h + T_r$	21.635
Prop.	$2T_e + 9T_h + T_f + 2T_r$	$T_e + 7T_h$	$6T_h$	20.441

C. Computation Time Comparison

To further evaluate the performance of our protocol, we compare the computation delay of the three schemes during the authentication phase across mobile devices, ground station servers, and drones. The basic operation times are listed in Table III. Specifically, T_e refers to the ECC multiplication, T_a refers to the ECC addition, T_h refers to the hash function, T_r refers to the random generation, and T_f refers to the fuzzy extractor.

Table III summarizes the total computation time of the login and authentication phase for each scheme.

As shown in Table IV, HEAT reduces authentication delay. It incurs a significantly lower time cost compared to the protocol proposed by Zhang et al. [14]. HEAT achieves much less delay compared with the schemes of Challa et al. [6] and Zhang et al. [14].

In large-scale IoD environments, clock synchronization issues among drones may introduce discrepancies. To mitigate these effects, we assume a maximum clock skew Δt between drones. Timestamp verification is performed within a tolerance window of $\pm \Delta t$ to account for synchronization errors. Additionally, periodic clock synchronization using GPS or network protocols can further reduce drift, ensuring reliable operation at scale.

VII. CONCLUSION

This article focuses on enhancing the protocol of IoD authentication and preventing session key leakage in data transmission. We propose the HEAT protocol, an ECC-based three-factor key agreement and authentication protocol, to reduce the authentication delay and enhance the authentication mechanism. The HEAT strictly follows the principles of RoM and eCK model. With comparative analysis, it is proven that the HEAT achieves higher data efficiency and lower authentication delay than existing works.

However, despite its advantages, there remain several limitations and open challenges for future work. The scalability of the HEAT protocol under large-scale drone swarms requires further investigation. Resistance to quantum-era threats has not yet been analyzed and represents an important direction for enhancing the protocol. Interoperability with emerging

technologies, such as blockchain or 5G-based IoD systems, remains an open issue. Addressing these challenges will be crucial for ensuring that HEAT can be effectively and securely deployed in diverse and evolving IoD environments.

As a conclusion, the HEAT is highly suitable for performing authentication operations in the IoD to ensure the security of subsequent data transmission in the IoD networks.

REFERENCES

- [1] E. T. Michailidis and D. Vouyioukas, "A review on software-based and hardware-based authentication mechanisms for the Internet of Drones," *Drones*, vol. 6, no. 2, p. 41, Feb. 2022.
- [2] J.-P. Yaacoub, H. Noura, O. Salman, and A. Chehab, "Security analysis of drones systems: Attacks, limitations, and recommendations," *Internet Things*, vol. 11, Sep. 2020, Art. no. 100218.
- [3] V. S. Miller, "Use of elliptic curves in cryptography," in *Proc. Conf. Theory Appl. Cryptograph. Techn.*, 1985, pp. 417–426.
- [4] H.-L. Yeh, T.-H. Chen, P.-C. Liu, T.-H. Kim, and H.-W. Wei, "A secured authentication protocol for wireless sensor networks using elliptic curves cryptography," *Sensors*, vol. 11, no. 5, pp. 4767–4779, May 2011.
- [5] W. Shi and P. Gong, "A new user authentication protocol for wireless sensor networks using elliptic curves cryptography," *Int. J. Distrib. Sensor Netw.*, vol. 9, no. 4, Apr. 2013, Art. no. 730831.
- [6] S. Challa et al., "Secure signature-based authenticated key establishment scheme for future IoT applications," *IEEE Access*, vol. 5, pp. 3028–3043, 2017.
- [7] M. Nikooghadam, H. Amintoosi, S. H. Islam, and M. F. Moghadam, "A provably secure and lightweight authentication scheme for Internet of Drones for smart city surveillance," *J. Syst. Archit.*, vol. 115, May 2021, Art. no. 101955.
- [8] Z. Ali, B. A. Alzahrani, A. Barnawi, A. Al-Barakati, P. Vijayakumar, and S. A. Chaudhry, "TC-PSLAP: Temporal credential-based provably secure and lightweight authentication protocol for IoT-enabled drone environments," *Secur. Commun. Netw.*, vol. 2021, pp. 1–10, Dec. 2021.
- [9] A. K. Das, M. Wazid, N. Kumar, A. V. Vasilakos, and J. J. P. C. Rodrigues, "Biometrics-based privacy-preserving user authentication scheme for cloud-based industrial Internet of Things deployment," *IEEE Internet Things J.*, vol. 5, no. 6, pp. 4900–4913, Dec. 2018.
- [10] S. Hussain, S. A. Chaudhry, O. A. Alomari, M. H. Alsharif, M. K. Khan, and N. Kumar, "Amassing the security: An ECC-based authentication scheme for Internet of Drones," *IEEE Syst. J.*, vol. 15, no. 3, pp. 4431–4438, Sep. 2021.
- [11] S. A. Chaudhry, T. Shon, F. Al-Turjman, and M. H. Alsharif, "Correcting design flaws: An improved and cloud assisted key agreement scheme in cyber physical systems," *Comput. Commun.*, vol. 153, pp. 527–537, Mar. 2020.
- [12] M. Wazid, A. K. Das, N. Kumar, A. V. Vasilakos, and J. J. P. C. Rodrigues, "Design and analysis of secure lightweight remote user authentication and key agreement scheme in Internet of Drones deployment," *IEEE Internet Things J.*, vol. 6, no. 2, pp. 3572–3584, Apr. 2019.
- [13] M. Zhang, C. Xu, S. Li, and C. Jiang, "On the security of an ECC-based authentication scheme for Internet of Drones," *IEEE Syst. J.*, vol. 16, no. 4, pp. 6425–6428, Dec. 2022.
- [14] M. Zhang, C. Xu, and J. Zhang, "Research on authentication key agreement protocol based on multi-factor in Internet of Drones," *Netinfo Secur.*, vol. 9, pp. 21–30, Sep. 2022.
- [15] K. Mahmood, Z. Ghaffar, M. Farooq, K. Yahya, A. K. Das, and S. A. Chaudhry, "A security enhanced chaotic-map-based authentication protocol for Internet of Drones," *IEEE Internet Things J.*, vol. 11, no. 12, pp. 22301–22309, Jun. 2024.
- [16] M. A. Saleem, Z. Ghaffar, K. Mahmood, A. K. Das, J. J. P. C. Rodrigues, and M. K. Khan, "Provably secure authentication protocol for mobile clients in IoT environment using puncturable pseudorandom function," *IEEE Internet Things J.*, vol. 8, no. 22, pp. 16613–16622, Nov. 2021.
- [17] G. Bleumer, *Random Oracle Model*. Boston, MA, USA: Springer, 2011, pp. 1027–1028.
- [18] M. Bellare and P. Rogaway, "Random oracles are practical: A paradigm for designing efficient protocols," in *Proc. 1st ACM Conf. Comput. Commun. Secur. - CCS*, 1993, pp. 62–73.
- [19] S. U. Jan, F. Qayum, and H. U. Khan, "Design and analysis of lightweight authentication protocol for securing IoD," *IEEE Access*, vol. 9, pp. 69287–69306, 2021.

- [20] L. Abualigah, A. Diabat, P. Sumari, and A. H. Gandomi, "Applications, deployments, and integration of Internet of Drones (IoD): A review," *IEEE Sensors J.*, vol. 21, no. 22, pp. 25532–25546, Nov. 2021.
- [21] M. Wazid, A. K. Das, and J.-H. Lee, "Authentication protocols for the Internet of Drones: Taxonomy, analysis and future directions," *J. Ambient Intell. Humanized Comput.*, pp. 1–10, Aug. 2018.
- [22] B. LaMacchia, K. Lauter, and A. Mityagin, "Stronger security of authenticated key exchange," in *Proc. Int. Conf. Provable Secur.*, 2007, pp. 1–16.
- [23] B. Bera, D. Chattaraj, and A. K. Das, "Designing secure blockchain-based access control scheme in IoT-enabled Internet of Drones deployment," *Comput. Commun.*, vol. 153, pp. 229–249, Mar. 2020.
- [24] J. Srinivas, A. K. Das, N. Kumar, and J. J. P. C. Rodrigues, "TCALAS: Temporal credential-based anonymous lightweight authentication scheme for Internet of Drones environment," *IEEE Trans. Veh. Technol.*, vol. 68, no. 7, pp. 6903–6916, Jul. 2019.
- [25] M. Turkanović, B. Brumen, and M. Hölbl, "A novel user authentication and key agreement scheme for heterogeneous ad hoc wireless sensor networks, based on the Internet of Things notion," *Ad Hoc Netw.*, vol. 20, pp. 96–112, Sep. 2014.
- [26] D. Wang and P. Wang, "Two birds with one stone: Two-factor authentication with security beyond conventional bound," *IEEE Trans. Dependable Secure Comput.*, vol. 15, no. 4, pp. 708–722, Jul. 2018.
- [27] S. Samanth, K. V. Prema, and M. Balachandra, "Security in Internet of Drones: A comprehensive review," *Cogent Eng.*, vol. 9, no. 1, Dec. 2022, Art. no. 2029080.

Xueru Zhang received the B.E. degree in data science and big data technology from Nanjing University of Science and Technology, Nanjing, China, in 2025. Her research interests include network security and cryptography.

Di Wu received the B.E. and M.E. degrees from Harbin Institute of Technology, Harbin, China, in 2013 and 2015, respectively, and the Ph.D. degree in electrical engineering from New Jersey Institute of Technology (NJIT), Newark, NJ, USA, in 2020.

He is currently an Associate Professor with the School of Cyber Science and Engineering, Nanjing University of Science and Technology, Nanjing, China. His current research interests include drone-assisted networks, edge computing, and network security.

Rui Zhang received the Ph.D. degree in computer science from Wuhan University, Wuhan, China, in 2023.

She is currently a Lecturer with the School of Cyber Science and Engineering, Nanjing University of Science and Technology, Nanjing, China. Her current research interests include the Internet of vehicles, artificial intelligence, and edge computing.